

Plantilla Reporte Ejecutivo GQM+PRAGMATIC CSCRМ

18 Diapositivas para Consejo de Administración / Comité de Dirección

Versión 1.0 · Documento (f) del Kit GQM+PRAGMATIC CSCRМ

"La diferencia entre un reporte de ciberseguridad que genera acción y uno que genera archivación es la calidad de los datos que lo sostienen."

Parámetros Generales

Parámetro	Valor
Diapositivas	18
Duración	30-40 min + Q&A
Formato	16:9 widescreen
Audiencia primaria	Consejo de Administración / Comité de Dirección / Comité de Auditoría
Audiencia secundaria	Regulador (CCN-CERT, INCIBE, supervisores sectoriales)
Paleta	Azul #1A2B4A · Naranja #E87722 · Verde #2ECC71 · Gris #95A5A6
Clasificación	CONFIDENCIAL — USO INTERNO RESTRINGIDO

DIAPOSITIVA 1 — PORTADA

Título: Diagnóstico CSCRМ con Marco GQM+PRAGMATIC

Subtítulo: [Organización] · [Sector] · [Mes/Año]

Elementos visuales: Red de nodos CS + gráfico radar en miniatura

Nota del presentador:

"Esta presentación no se basa en métricas elegidas por comodidad. Cada indicador ha sido derivado desde objetivos nacionales de ciberseguridad (GQM) y calificado con PRAGMATIC para garantizar que mide lo que dice medir."

DIAPOSITIVA 2 — EL PROBLEMA: MÉTRICAS QUE NO MIDEN

Columna izquierda — Lo habitual:

"47 métricas. Todas en verde. El CISO presenta. El CEO asiente. Y la organización lleva 254 días comprometida a través de un proveedor que aparecía como 'gestionado'."

Columna derecha — Con GQM+PRAGMATIC:

"20 indicadores seleccionados por trazabilidad (GQM) y verificados por calidad (PRAGMATIC). Solo métricas que anticipan, que accionan y que no mienten."

Datos de impacto:

- 22,5% de las brechas involucran a terceros/proveedores (ENISA NIS360 2025)
- MTDD-SC medio: **254 días** (Cipher/Prosegur 2026)
- Coste medio por incidente CS: **4,33 M€** (Cipher/Prosegur 2026)

DIAPOSITIVA 3 — LOS DOS PILARES DEL MARCO

GQM: OBJETIVO NACIONAL — Pregunta Operativa — Indicador
Basili & Rombach (1988) / SEI CMU. Garantiza trazabilidad estratégica.

PRAGMATIC: P-R-A-G-M-A-T-I-C

Brotby & Hinson (2013, CRC Press). Escala 0-81. Umbral alta calidad: ≥65.

DIAPOSITIVA 4 — LOS CUATRO OBJETIVOS GQM NACIONALES

Objetivo	Contexto	Indicadores	Norma clave
O1 — Reducir incidentes CSCRМ	22,5% brechas de terceros	M01-M04	NIS2 Art. 23
O2 — Madurez CSCRМ ≥ L3	IGM España ~2,1 / objetivo 3,0	M05-M09, M17-M18, M20	NIST SP 800-161r1
O3 — Visibilidad n-tier	80% sin evaluación subcontratistas	M10-M12, M19-M20	NIS2 Art. 22 / CRA
O4 — Respuesta coordinada	~30% con PRI que incluye CS	M13-M16	NIS2 Art. 21.2.a, 23, 29

DIAPOSITIVA 5 — RESULTADOS PRAGMATIC

Gráfico de barras horizontales (de mayor a menor puntuación):

- Verde: ≥65 pts (Alta calidad) · Naranja: 40-64 (Media) · Línea de referencia en 65

Resumen:

- **13 de 20** indicadores alcanzan alta calidad PRAGMATIC
- Fortaleza: **Relevante** (9,0 media) — todos con anclaje normativo
- Brecha: **Independiente** (6,6 media) — plan: triangulación con auditorías externas

DIAPOSITIVA 6 — IGM GLOBAL Y POSICIÓN RELATIVA

IGM Global: [X,X] / 5,0 — [Nivel] — [semáforo]

Tabla de subíndices:

Dominio	IGM org.	España estim.	UE media	Objetivo L3
Gobernanza	[x]	~2,2	~3,1	3,0
Identificación	[x]	~2,0	~2,8	3,0
Protección	[x]	~1,8	~2,6	3,0

| Detección | [x] | ~1,6 | ~2,4 | 3,0 |
| Resiliencia | [x] | ~2,1 | ~2,9 | 3,0 |

DIAPPOSITIVA 7 — CONJUNTO MÍNIMO VIABLE (CMV)

Indicador	Valor Actual	Objetivo 2028	PRAGMATIC	Estado
M02 MTDD-SC	[X]d	<90d	66	[semáforo]
M07 IGM	[X,X]	≥3,0	69	
M09 Brecha Dom.	[X,X]	≤1,0	75	
M11 SBOM	[X]%	≥50%	72	
M13 PRI con CS	[X]%	≥70%	69	
M14 Plazos NIS2	[X]%	≥95%	75	
M18 Contratos	[X]%	≥80%	75	
M20 Ciclo Vida	[X,X]	≥3,5	78	

"Si solo podemos medir 8 cosas, que sean estas. Cubren los 4 objetivos GQM nacionales."

DIAPPOSITIVA 8 — EL INDICADOR MÁS PREOCUPANTE: MTDD-SC

Valores grandes:

- Nuestro MTDD-SC: [XXX] días | Benchmark: 254 días | Objetivo 2028: <90 días

"Cada día de exceso es un día en que el atacante opera con total libertad. A 254 días, ya conoce nuestros sistemas mejor que muchos de nuestros propios empleados."

Acción requerida: Monitorización continua proveedores → Coste: [X] €/año → ROI estimado: [Y]%

DIAPPOSITIVA 9 — INDICADORES EMERGENTES: SBOM, PQC, IA

Indicador	Cobertura actual	Obligación	PRAGMATIC	Acción Q3-2026
SBOM (M11)	[X]%	CRA 2025-27	72	Exigir en próximas 5 renovaciones
PQC (M12)	Nivel [X]/4	Roadmap CE 2026-35	63	Iniciar inventario criptográfico
IA/ML (M19)	[X]% eval.	Reg. IA UE 2024	63	Incluir cláusula AIBOM en 2026

DIAPPOSITIVA 10 — EL MÁS FIABLE: CICLO DE VIDA DEL PROVEEDOR (M20, 78 pts)

SELECCIÓN → ONBOARDING → MONITORIZACIÓN → OFFBOARDING
[L x/5] [L x/5] [L x/5] [L x/5]

Por qué es el indicador más fiable: predice accesos no revocados (Predictivo: 9), verificable por auditoría (Genuino: 9), difícilmente falsificable (Independiente: 6 — el más alto del grupo).

"Pregunta al Consejo: ¿Cuántos proveedores con contratos vencidos tienen todavía acceso activo a nuestros sistemas? No es una pregunta retórica."

DIAPOSITIVA 11 — ANÁLISIS POR CRITERIO PRAGMATIC

Criterio	Media	Evaluación
Relevante	9,0	✓ Máxima fortaleza
Accionable	8,7	✓ Muy alta
Significativo	8,1	✓ Alta
Oportuno	8,1	✓ Alta
Rentable	7,8	✓ Alta
Genuino	7,2	✓ Buena
Preciso	7,2	✓ Buena
Predictivo	6,3	⚠ Moderada
Independiente	6,6	⚠ Brecha principal

DIAPOSITIVA 12 — COMPARATIVA INTERNACIONAL

Indicador	España estim.	Media UE	P75 UE	Objetivo NIS2
IGM Global	~2,1	~2,6	~3,4	≥3,0
MTTD-SC	~254d	~220d	~90d	<60d
Política CSCRm formal	~60%	~72%	~90%	≥90%
Due Diligence	~40%	~47%	~70%	≥75%
SBOM exigido	~15%	~22%	~40%	≥50% (CRA)
PRI con CS	~30%	~38%	~60%	≥70%

Fuentes: ENISA NIS360 2025 · ENISA NIS Investments 2025 · Cipher/Prosegur 2026

DIAPOSITIVA 13 — ROI POR INDICADOR

Indicador	Inversión estim.	Reducción ALE	ROI 3 años
M18 Cláusulas	~10.000 €	~300.000 €	~2.900%
M20 Ciclo Vida	~50.000 €	~800.000 €	~1.500%
M14 Plazos NIS2	~15.000 €	~200.000 €	~1.233%
M02 MTTD-SC	~120.000 €	~1.200.000 €	~900%
M11 SBOM	~60.000 €	~500.000 €	~727%

Basado en FAIR Institute 2025 + ALE con CMI-SC = 4,33 M€ (Cipher/Prosegur 2026)

DIAPOSITIVA 14 — PLAN DE ACCIÓN PRIORIZADO (18 MESES)

#	Indicador	Acción	Resp.	T1	T2	T3	T4	27	Norma
1	M20 Ciclo Vida	Formalizar offboarding + auditoría accesos	CISO+IT	■	■				ENS/NIS2
2	M18 Contratos	Actualizar plantilla + revisar top 20	Legal+CISO	■	■				NIS2
3	M14 Plazos NIS2	Entrenar PRI + simulacro 24h	CISO+NOC	■					NIS2
4	M09 Brecha Dom.	Gap analysis por dominio	CISO ext.	■	■				IMC
5	M02 MTTD	Monitorización continua proveedores	NOC+CISO		■	■	■		NIST CSF
6	M11 SBOM	Exigir SBOM en renovaciones sw	Compras			■	■		CRA
7	M13 PRI	Actualizar PRI con módulo CS	CISO		■				ENS/NIS2

8	M07 IGM	Encuest a CSCRM complet a (línea base)	CISO						IMC
---	------------	---	------	--	--	--	--	--	-----

DIAPOSITIVA 15 — LO QUE EL REGULADOR MIRARÁ PRIMERO

1. M14 Plazos NIS2 — Verificable por CCN-CERT con timestamps. Sanción: hasta 10 M€.
2. M05 Política Formal — Primera verificación documental en cualquier supervisión.
3. M06 Inventario Proveedores — Exigido ENS op.ext.1 + NIS2 Art. 21.2.d. Verificable por auditoría.
4. M13 PRI con CS — Comprobación estándar en ejercicios supervisados INCIBE/CCN-CERT.
5. M18 Cláusulas Contractuales — NIS2 Art. 21.4. Verificable en revisión de contratos.

DIAPOSITIVA 16 — DECISIONES REQUERIDAS AL CONSEJO

Decisión	Urgencia	Propone	Inversión	Plazo
Aprobar presupuesto CSCRM 2026-2027	● Alta	CISO	[importe]	Próximo Consejo
Designar Responsable CSCRM / POC ENS	● Alta	CEO	—	30 días
Autorizar auditoría de accesos activos	● Alta	CISO	[importe]	30 días
Aprobar actualización plantilla contractual	● Media	Legal+CISO	[importe]	90 días
Autorizar gap analysis NIS2 con tercero	● Media	CISO	[importe]	90 días
Aprobar plan migración PQC (inventario cript.)	● Media	CISO+CTO	[importe]	6 meses

DIAPPOSITIVA 17 — TRES PREGUNTAS PARA EL CONSEJO

6.

De los 20 indicadores CSCRМ que este marco propone medir, ¿cuántos medíamos antes? ¿Por qué?

7.

El criterio PRAGMATIC más débil es la Independencia: la mayoría de nuestros datos son autodeclarados. ¿Estamos dispuestos a invertir en verificación externa de los indicadores más críticos?

8.

El indicador M20 (78/81 PRAGMATIC) mide el ciclo de vida completo del proveedor, incluyendo el offboarding. ¿Sabemos hoy cuántos accesos activos de ex-proveedores tenemos?

De los 20 indicadores CSCRМ que este marco propone medir, ¿cuántos medíamos antes? ¿Por qué?

El criterio PRAGMATIC más débil es la **Independencia**: la mayoría de nuestros datos son autodeclarados. ¿Estamos dispuestos a invertir en verificación externa de los indicadores más críticos?

El indicador M20 (78/81 PRAGMATIC) mide el ciclo de vida completo del proveedor, incluyendo el offboarding. **¿Sabemos hoy cuántos accesos activos de ex-proveedores tenemos?**

"En ciberseguridad, la diferencia entre una organización resiliente y una vulnerable no está en el número de controles implementados, sino en la calidad de los datos que usa para decidir cuáles implementar."

DIAPPOSITIVA 18 — CONTRAPORTADA Y PRÓXIMOS PASOS

Próximos pasos:

- [] Completar la Plantilla Excel con valores actuales de los 20 indicadores
- [] Revisar la puntuación PRAGMATIC con el equipo de ciberseguridad
- [] Presentar al Comité de Auditoría el plan de mejora de indicadores con PRAGMATIC < 65
- [] Iniciar verificación independiente de los 3 indicadores más críticos

Referencias:

- Basili & Rombach (1988) IEEE TSE 14(6)
- Brothby & Hinson (2013) PRAGMATIC Security Metrics, CRC Press
- NIST SP 800-55v2 dic. 2024
- INCIBE-CERT IMC v2.8
- NIST SP 800-161r1 act. nov. 2024